

Comparative Analysis of Authentication Systems in Wireless and Cloud Environments

Authentication is an important part of cybersecurity because it determines who has the authority to access a system. In both wireless and cloud environments, authentication methods are needed to ensure data is secure, access is monitored, and trust is maintained across systems. Different authentication technologies are needed for different use cases. For example, some are meant for identity management, while others are meant for cloud authorization. This paper discusses the four most common authentication technologies: RADIUS, TACACS+, LDAP, and OAuth. Even though these technologies are often discussed together in enterprise environments, they each serve a different role in authentication. RADIUS is most commonly used for network access authentication, TACACS+ is used for device administration, LDAP is used as a directory service and identity store, and OAuth is primarily used for delegated authorization in cloud environments. The comparison of these technologies in this paper will help us understand how authentication is designed across both wireless and cloud environments. RADIUS, TACACS+, LDAP, and OAuth all contribute towards authentication management, but they each differ in purpose, architecture, and threat exposure; choosing the right one depends on the context of the problem, as well as any security requirements in the environment.

In enterprise environments, AAA, authentication, authorization, and accounting, are the foundations for security and visibility into system use. Authentication makes sure users are who they say they are, authorization determines what permissions a user has, and accounting tracks user activity such as login times or commands. RADIUS and TACACS+ are both AAA protocols, while OAuth is an authorization framework usually used in the cloud, and LDAP is a protocol acting as a middleman to access directory information. LDAP does not perform authentication itself, but instead stores any credentials needed. In wireless networking, 802.1X and EAP (Extensible Authentication Protocol) are important for authentication. These mechanisms help require clients to authenticate before they can get access to the network. A wireless access point usually forwards these authentication requests to a backend server, such as a RADIUS server.

This way, security policies are consistent and access control becomes centralized. Cloud environments instead focus on token based authorization and SSO (Single Sign-On). Users usually authenticate through an identity provider and get tokens to access the cloud.

RADIUS, or Remote Authentication Dial-In User Service, is a protocol commonly used in enterprise wireless environments, VPNs, and network access control systems, for centralized authentication, authorization, and accounting. A client will try to join the network, the access point forwards the request to the RADIUS server, and the RADIUS server will validate the credentials of the client by checking it with the authentication database. RADIUS servers also decide permissions given to the client, as well as access to networks. If approval is sent back to the client, access will be given to the user. RADIUS servers provide centralized authentication for large networks, and with 802.1X and EAP integration, RADIUS helps prevent bad actors from accessing the network. 802.1X is a port-based mechanism that verifies authentication before granting access, while EAP exchanges information between the client and the authentication server. This means RADIUS is a good fit when the use case is Wi-Fi access with zero trust. RADIUS can also assign users to specific VLANs which helps with security. However, RADIUS still has weaknesses. For one, it is quite old, and still uses the MD5 hash algorithm, which has been considered insecure for several years due to its weakness towards collision attacks; where different attempts can produce the same hash. Ideally, a hash would have a different output for every input, but that is mathematically impossible. A collision is when two different inputs result in the same output. MD5 was cracked where collisions were easily made, creating a weakness for RADIUS [1]. Later in this paper, a case study of a real life exploitation of this vulnerability will be performed. Also, only the password is encrypted in the authentication request, meaning information such as usernames or IP addresses are visible. The RADIUS protocol also does not heavily authenticate servers, leaving it vulnerable to Man-in-the-Middle attacks if networks are not properly protected with security such as TLS (Transport Layer Security), a cryptographic protocol that ensures data is sent securely and privately across the web. RADIUS is usually used for network access through user authentication. TACACS+, similarly, is another AAA protocol, but it aims to target a different use case.

TACACS+ (Terminal Access Controller Access-Control System Plus) is an AAA protocol that offers higher security than RADIUS. TACACS+ encrypts all packets of data transmitted, not just the password as RADIUS does. TACACS+ also allows for different privilege levels and different protocols for authentication versus authorization, generally

granting more flexibility. However, TACACS+ does not support 802.1X, and is also proprietary to Cisco, meaning it only works on Cisco devices. This, along with the higher price of TACACS+ servers, usually leads to higher costs, and reduced support.

TACACS+ has a similar flow of operations as RADIUS, where the access point sends a request to the TACACS+ server to authenticate a user, the TACACS+ server checks its authentication database to see if the credentials are valid before sending its response back to the access point, and the access point grants or denies access based on the response. However, the TACACS+ server also informs the access point about what resources the client is allowed to access, granting more control. Because of this increased security and control, TACACS+ is usually better for high-stakes industries such as finance, as well as being used for administrating network devices such as routers or switches. Since TACACS+ is primarily designed for device administration, it is limited in its scope.

OAuth, or Open Authorization, is a network protocol for authorization specifically. OAuth allows users to authorize one application to interact with another on their behalf, no password needed. Instead, it uses tokens to share authorization data, so clients can access protected information for a user. OAuth works well in cloud environments where different services must interact, and also integrates well with SSO. However, there are disadvantages to OAuth as well. Since it uses tokens to grant access, if these tokens are stolen or misplaced, then the system has been breached, since these tokens can be reused. Credential theft is removed as a concern since passwords and such are not shared, but this also means token security becomes important as well. OAuth is usually recommended to complement other protocols that will perform the authentication and accounting, since it is solely for authorization.

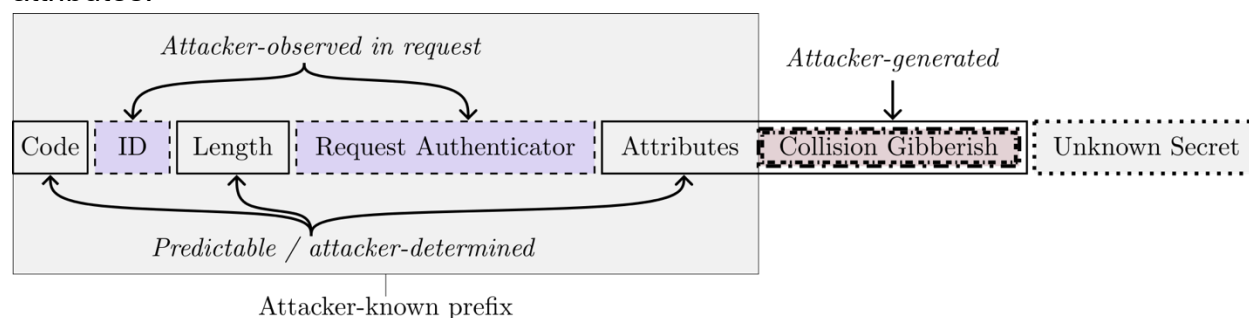
LDAP, or Lightweight Directory Access Protocol, is a protocol used to manage directory services. LDAP is not an authentication protocol but instead a centralized database that stores information such as usernames and passwords, organizational information, or networks assets. Other services can connect to the LDAP server to validate users against stored usernames and passwords. LDAP is designed to be fast even for large datasets, and works across most common operating systems. A client will connect to the LDAP server and send operation requests, such as adding or modifying entries in the database, with the LDAP server returning responses in any order. Since LDAP servers store such sensitive information, it becomes a high value target for bad actors. LDAP is also vulnerable to injection attacks. When user input isn't properly sanitized by an application, a local proxy can modify LDAP statements and potentially result in permissions granted to unauthorized queries [2].

Authentication systems are frequently targeted by bad actors because these systems protect sensitive data. In both cloud and wireless environments, credential theft, replay attacks, and downgrade attacks all are threats that appear in real life scenarios. Credential theft is where the authentication secrets are stolen, whether that be passwords, tokens, or whatever else. In RADIUS environments, usernames and passwords are usually used for credentials, so if authentication methods are insufficient and the credentials are captured, then bad actors can gain access. Since TACACS+ usually acts as an administrative control, capturing admin credentials would have much greater consequences. Additionally, despite TACACS+ encrypting the entire packet compared to RADIUS only encrypting the password, TACACS+ also still relies on the outdated and broken MD5 hash. Meanwhile, LDAP credentials can be stolen by LDAP injections as mentioned prior, or by network sniffing, listening to the network traffic and intercepting usernames and passwords as they are transmitted. Once credentials have been stolen, then the database becomes exposed. OAuth uses tokens instead of passwords, but these still have a risk when stolen as well. Bad actors will create malware or phishing links that can scrape data directly from the user's browser local storage or trick the user into granting them permission with a fake website. Once these tokens have been stolen, attackers can bypass MFA (Multi-Factor Authentication) completely, since the token is given after authentication. Refresh tokens, which are used to get new access tokens, can last up to months, creating a security risk if those tokens were stolen.

Replay attacks are when a valid authentication exchange is captured and reused by a bad actor to gain access to the system. How effective replay attacks are against a system usually depend on whether it rejects old messages so they cannot be reused. RADIUS servers are vulnerable to replay attacks due to the MD5 hash it uses being broken, allowing attackers to modify packets without knowing the secret. RADIUS needs additional anti-replay attack mechanisms to protect against replay attacks. TACACS+ encrypts the contents of the packets, not just the passwords, but does not use timestamps or some other way to determine whether packets are fresh or old. This means that it remains vulnerable to replay attacks, since it also uses the MD5 hash. To help deal with this vulnerability, the network path between clients and the TACACS+ server should be secured from sniffing. LDAP servers are also vulnerable to replay attacks. If an attacker manages to gain access of a valid LDAP request, that captured information can be reused to bypass authentication by impersonating the validated user. To deal with this vulnerability, the system can implement LDAP signing, so all traffic is cryptographically signed such that Man-in-the-Middle and replay attacks are prevented.

Downgrade attacks are a type of Man-in-the-Middle attack where bad actors force systems to rollback their security protocols to older, insecure protocols, which have weaker encryption. These attacks are especially dangerous in systems which have backwards compatibility, because they can be rolled back to more vulnerable states. When using RADIUS servers, the risks grow when weaker EAP (Extensible Authentication Protocol) are still enabled. In TACACS+ environments, downgrade attacks become a risk when the server allows falling back to non TLS connections (local authentication), which can be mitigated by only allowing TLS protected connections to proceed. LDAP can also be vulnerable to this kind of attack if connections are not secured, which can be done by requiring LDAP signing, enabling channel binding, and keeping systems up to date. OAuth uses PKCE, or Proof Key for Code Exchange, to prevent stealing of authorization codes. Static secrets are replaced by a verification handshake, which limits the risk of bad actors getting access to tokens. However, OAuth can be vulnerable to a PKCE downgrade attack when the authorization server doesn't mandate PKCE for all authorization requests [3].

In 2024, a new flaw was discovered in RADIUS. The Blast-Radius attack “allows a man-in-the-middle attacker between the RADIUS client and server to forge a valid protocol accept message in response to a failed authentication request” [1]. When clients send an authentication request to the RADIUS server, the packet includes a Request Authenticator, which is just a random nonce, and the response packet sent by the server has a Response Authenticator, which uses the MD5 hash discussed prior for encryption. According to this research paper, the vulnerability is created when an attacker generates a malicious Proxy-State attribute that is inserted after the packet attributes:



[1]

If the correct Proxy-State is inserted, then the response from the server to the modified request will have the same Response Authenticator as a response to the correct request, and access will be granted, removing the need for obtaining a password or secret. This issue is related to a fundamental problem of RADIUS: it relies on MD5

hashing, which is old and broken. This is a major reason for why RADIUS standards needed to be updated. According to DeKok, the long term fix for these issues is an overhaul of the RADIUS model [4]. RadSec is a security model for transporting RADIUS datagrams over TCP and TLS, which encrypts the transmitted packets, solving the issue of Man-in-the-Middle attacks. Although the overhaul of RADIUS is needed, RADIUS/UDP (User Datagram Protocol) will still probably be used for years, which means that the issues in older deployments still need to be resolved. This can be done by including and validating the Message-Authenticator attribute in packets sent both from and to the server.

In 2025, a new vulnerability of TACACS+ was discovered, named CVE-2025-20160. This vulnerability occurs when a Cisco device is configured to use TACACS+ but has at least one required TACACS+ shared secret not configured [5], with Cisco giving it a 8.1 CVSS 3.1 score, which standardizes vulnerabilities on a 0 to 10 scale. Usually when the shared secret is configured, both the client and server know that secret and use it to protect the packet body, but without the secret being defined, a bad actor performing a Man-in-the-Middle attack could intercept the packets and read them or impersonate the server, granting authorization. Cisco released software updates mitigating this vulnerability, but administrators should still verify that they have defined a shared secret for every TACACS+ server.

Recently, Vercel, an American cloud application company, announced that they were breached, due to an employee's device being infected with third-party malware that stole the employee's OAuth tokens. The OAuth token was then used to gain access to the employee's Google Workspace account as well as Vercel's internal systems, and steal data [6]. This breach is informative because it shows how the attacker used the OAuth access to gain access to other systems. Originally, the breach was not linked to the Google Workspace account at all until the employee gave the malware full permissions, assuming it was a working AI tool instead of malicious code. This shows how even if a breach occurs on just one platform, it can spread easily through those compromised tokens. It also shows how OAuth permissions should not be broadly granted, but instead have privileges reduced to the use case.

The best practices for authentication protocols truly depends on the use case. For enterprise wireless environments, RADIUS with 802.1X is best because 802.1X provides strong authentication while RADIUS enforces its centralized policy throughout, and scalability is easy for RADIUS. When it comes to administrative access over

network controls such as switches, routers, or firewalls, TACACS+ is preferred since it offers different privilege levels as well as different protocols for authorization versus authentication, but administrative access needs to be protected with multi-factor authentication and such to prevent vulnerabilities. LDAP is mainly handles directory services. Other services use LDAP to access the directory and check identity through that. If LDAP is compromised though, the breach could spread throughout other services. In cloud environments, OAuth enables access to other services without needing to expose any credentials, relying on access tokens instead. However, in order to be secure, care must be maintained around these tokens, so they are short-lived and highly protected. If these tokens are exposed, other services could be vulnerable too.

Authentication systems are needed in security for both wireless and cloud environments, but the specific system depends on the use case. RADIUS is best for wireless enterprise control, TACACS+ is best for managing network devices, LDAP is best as a centralized directory, and OAuth is used in the cloud for authorization. You cannot simply replace one system for another; they each play their own role in network security as a whole.

Citations:

[1]

S. Goldberg *et al.*, "RADIUS/UDP Considered Harmful." Accessed: Apr. 25, 2026. [Online]. Available: <https://www.blastradius.fail/pdf/radius.pdf>

[2]

"LDAP Injection | OWASP," *owasp.org*. https://owasp.org/www-community/attacks/LDAP_Injection

[3]

"draft-ietf-oauth-security-topics-19," *datatracker.ietf.org*. <https://datatracker.ietf.org/doc/html/draft-ietf-oauth-security-topics>

[4]

A. DeKok, "Deprecating Insecure Practices in RADIUS," *IETF Datatracker*, 2024. <https://datatracker.ietf.org/doc/draft-ietf-radext-deprecating-radius/> (accessed Nov. 15, 2024).

[5]

"Cisco IOS and IOS XE Software TACACS+ Authentication Bypass Vulnerability," *Cisco.com*, Sep. 24, 2025.

<https://sec.cloudapps.cisco.com/security/center/content/CiscoSecurityAdvisory/cisco-sa-ios-tacacs-hdB7thJw> (accessed Oct. 01, 2025).

[6]

“The Vercel Breach: OAuth Supply Chain Attack Exposes the Hidden Risk in Platform Environment Variables,” *Trend Micro*, Apr. 20, 2026.
https://www.trendmicro.com/en_us/research/26/d/vercel-breach-oauth-supply-chain.html

[7] C. Rigney, S. Willens, A. Rubens, and W. Simpson, “Remote Authentication Dial In User Service (RADIUS),” *www.rfc-editor.org*, Jun. 2000, doi: <https://doi.org/10.17487/RFC2865>.

[8] C. Finseth, “An Access Control Protocol, Sometimes Called TACACS,” *IETF*, Jul. 01, 1993.
<https://datatracker.ietf.org/doc/html/rfc1492> (accessed Feb. 18, 2024).

[9] Cisco, “TACACS+ and RADIUS Comparison,” *Cisco*, May 2017.
<https://www.cisco.com/c/en/us/support/docs/security-vpn/remote-authentication-dial-user-service-radius/13838-10.html>